

What attacks/vulnerabilities have we seen in practice?

- **Plugin issues:**
 - Remote code execution via 'eval()' statements
 - Server-side request forgery via unparameterized plugin
 - SQL injection via unparameterized plugin
 - Potential XSS via unescaped HTML rendering
 - Session data exfiltration via markdown rendering
- **Indirect prompt injection**
 - Tampering with summarization results
 - Providing incorrect Q&A results
 - Individually targeted corruption of search results
 - Guardrail bypasses leading to leakage of potentially sensitive information
- **Incorrect or undocumented trust boundaries**
 - Incorrect permissions handling on confidential documents
 - Insecure storage of logs containing session content
- **Et cetera**
 - Information leakage via guardrail refusals



In his presentation, Richard Harang, Principal Security Architect (AI/ML), NVIDIA, further highlighted different types of prompt injections, including direct and second-order (indirect) injections in LLMs, and their cybersecurity implications. The indirect variant, for example, can allow attackers to alter the behaviour of an LLM by inserting malicious instructions into data sources that the model later processes, potentially leading to misinformation or data leakage, according to Harang.

To delve deeper into these topics, NVIDIA has detailed these issues in several articles on its developer blogs and forum. They describe how attackers can exploit vulnerabilities in LLM plugins, such as those in the LangChain library – a popular open-source framework for building apps and plugins on LLMs – to manipulate LLM responses, leading to potentially severe consequences like remote code execution or SQL injection.

Harang's presentation underlined an important nature of AI security with respect to LLMs. That LLMs don't reason, they make statistical predictions on what words are most likely to follow some other words, in which case

"Hallucinations and prompt injection naturally follow," he emphasised. Food for thought.

Deep backdoors in AI agents

Another AI advancement taken to task at Black Hat 2024 was Deep Reinforcement Learning (DRL), a powerful technique for training AI agents to make decisions, which has seen rapid adoption across various industries in recent months. However, this technology is not without its risks, according to a recent study from The Alan Turing Institute which highlights a critical cybersecurity vulnerability: backdoors.

Unlike traditional software backdoors that exploit code vulnerabilities, these backdoors are embedded within the neural network itself, according to a group of researchers presenting their findings at Black Hat 2024. According to the study, the backdoors act as malicious triggers, designed to blend seamlessly into normal data, and can manipulate an agent's behaviour when activated.

Imagine a sophisticated LLM or GenAI model designed to provide accurate and unbiased information. It's trained on vast amounts of text data

to generate human-quality text and answer your questions in an informative way. But what if this model has been secretly manipulated to produce harmful or misleading information under specific conditions? This is essentially a backdoor in an LLM. It's like a hidden trigger that, when activated, causes the model to deviate from its intended behaviour. For example, a language model might be programmed to generate hateful content when presented with a seemingly innocuous but specific phrase. This backdoor could be incredibly difficult to detect, as it would blend seamlessly into the model's normal output.

Existing defence mechanisms often prove ineffective against these sophisticated backdoors in Deep Reinforcement Learning. Hence, the researchers propose a novel approach to detect these malicious patterns by analysing the neural network's internal activations during runtime. Through experiments, they demonstrated the potential of this method in identifying hidden backdoors. This research underscores the urgent need for robust security measures to protect DRL systems from malicious attacks. **d**